

INFORME TÉCNICO DE AUDITORÍA DE SEGURIDAD

Hallazgo: Carga de Archivos sin Restricciones en la Aplicación Web

Control de versiones

Versión

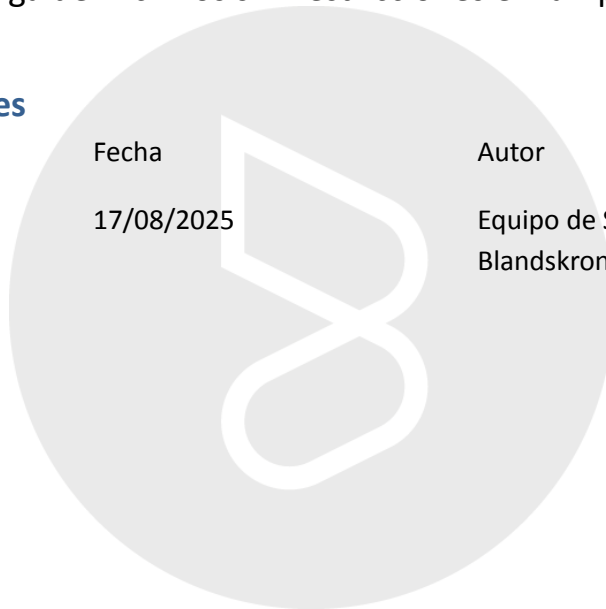
1.0

Fecha

17/08/2025

Autor

Equipo de Seguridad -
Blandskron SpA



Resumen Ejecutivo

La aplicación web presenta una vulnerabilidad crítica al permitir la carga de archivos sin restricciones adecuadas. Esta falla posibilita que un atacante suba y ejecute scripts maliciosos en el servidor, lo cual representa un riesgo significativo de compromiso total de la infraestructura tecnológica. El presente informe expone el hallazgo, la evidencia técnica que lo respalda, los impactos potenciales y las recomendaciones para su mitigación.

Título del Hallazgo

Carga de Archivos sin Validación ni Restricciones en Endpoint Público

Resumen Técnico

Se detectó que el sistema de carga de archivos de la aplicación permite subir contenido sin validar el tipo MIME, la extensión ni la autenticidad del usuario. Esta falta de controles habilita la posibilidad de subir archivos ejecutables que pueden ser accedidos y ejecutados en el servidor.

Evidencia Técnica

Durante la auditoría se interceptó la solicitud POST hacia el endpoint de carga utilizando Burp Suite. Se subió un archivo PHP denominado shell.php sin ser bloqueado por el servidor. Al acceder a la URL correspondiente, se logró ejecutar comandos arbitrarios, confirmando la vulnerabilidad. La prueba incluyó la ejecución del comando ``whoami``, obteniendo como resultado la cuenta de servicio activa en el servidor.

Impacto Potencial

Un atacante puede explotar esta vulnerabilidad para ejecutar código remoto en el servidor, obteniendo control total sobre el sistema. Esto incluye robo de datos, instalación de malware, escalamiento de privilegios y persistencia en la infraestructura. El riesgo se amplifica al no requerirse autenticación para realizar la carga de archivos.

Recomendación Técnica

1. Restringir los tipos de archivo permitidos mediante filtros de tipo MIME y extensión en el backend, complementados con validaciones en el frontend.
2. Implementar autenticación obligatoria y control de roles para acceder al módulo de carga, limitando su uso a usuarios autorizados.
3. Aislar los archivos subidos en un directorio sin permisos de ejecución y configurar reglas en el servidor para evitar la ejecución desde este espacio.
4. Registrar y monitorear cada intento de carga en logs de auditoría, incluyendo dirección IP, nombre del archivo, usuario y timestamp.

Observaciones Finales

La vulnerabilidad identificada demuestra la importancia de implementar controles adecuados en los mecanismos de carga de archivos. Las recomendaciones propuestas permitirán reducir drásticamente el riesgo, fortaleciendo la postura de seguridad de la aplicación y asegurando una operación más confiable.

